JÖNKÖPING UNIVERSITY

Systemadministration – Windows

Föreläsning 4 – Active Directory

04/09/2024

Planering

Vecka	Dag	Aktivitet
13	~~Mån~~	~~**Föreläsning** – Kursintroduktion, introduktion till Windows-miljöer~~
	~~Ons~~	~~**Laboration & Redovisning laboration 1**~~
14	-	~~**Föreläsning** – Windows-klienter~~
	-	~~**Föreläsning** – Windows Server~~
	~~Fre~~	~~**Laboration & Redovisning laboration 1**~~
15	Mån	**Föreläsning** – Active Directory (AD)
	Fre	**Laboration & Redovisning laboration 2**
16	Mån	**Föreläsning** – Administration, övervakning och PowerShell
	Fre	**Laboration & Redovisning laboration 3**
17	Mån	**Föreläsning** – M365, Entra ID och Azure
	Fre	**Laboration**
18	Mån	**Föreläsning** – Intune, Defender och enhetshantering
	Fre	**Laboration & Redovisning laboration 4**
19	Mån	**Föreläsning** – Patch-hantering, övervakning och omvärldsbevakning
	Ons	**Laboration & Redovisning laboration 5**
20	Mån	**Föreläsning** – Reserv
	Fre	**Laboration & Redovisning laboration 6**
21	Fre	**Pluggvecka**, extra tillfälle för **labbredovisningar**
22		**Tentamen**

JÖNKÖPING UNIVERSITY

Active Directory Domain Services

Active Directory Domain Services (AD DS)

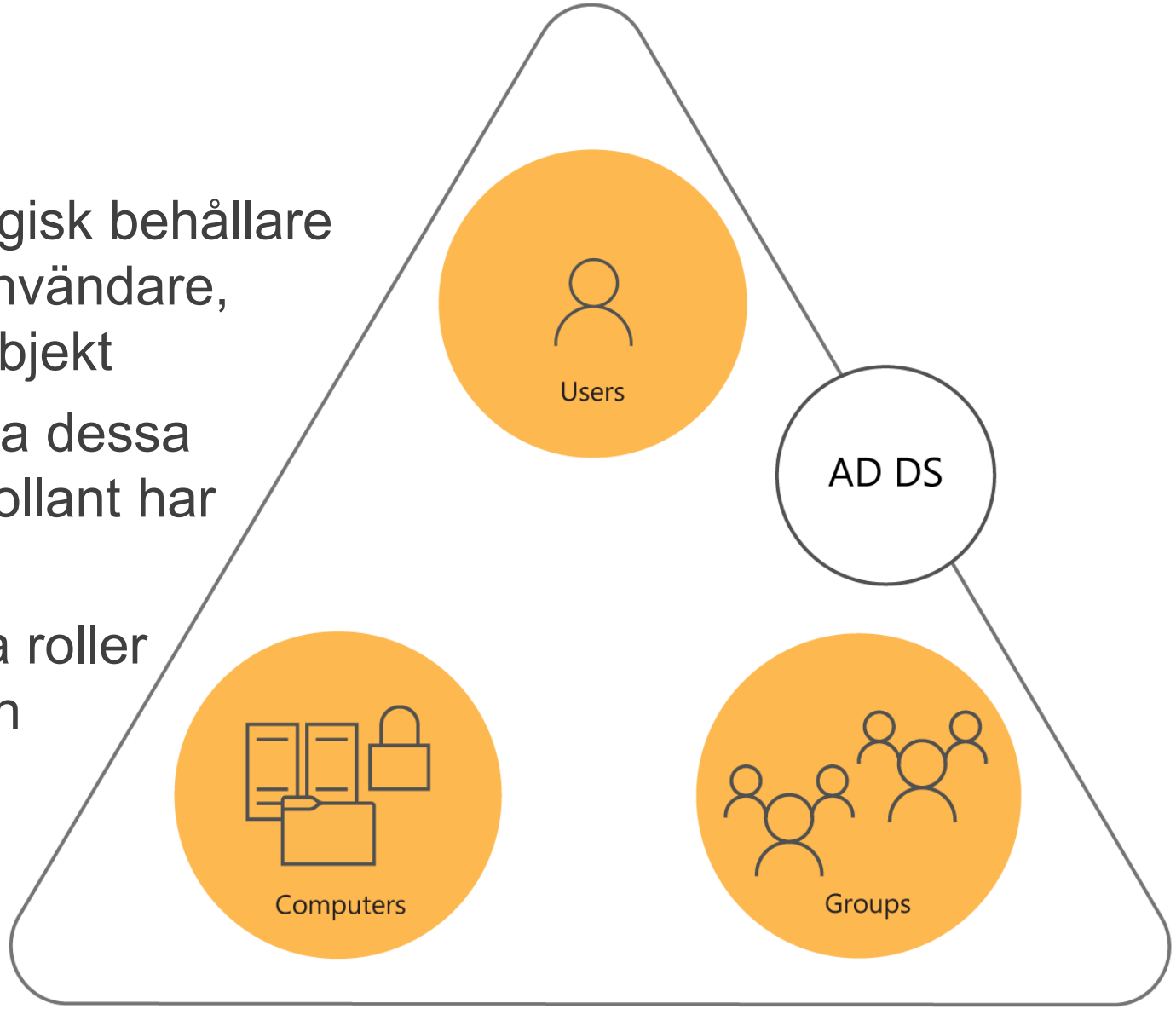
- **AD DS** är grundstommen för Windows-baserade IT-miljöer som hanterar flera olika typer av **objekt**:
  - Användarkonton
  - Datorer
  - Servrar
  - Grupper
  - Etc.
- Skapar en sökbar och hierarkisk katalog för att applicera konfiguration och säkerhetsinställningar för objekt i en **domän**
- Databasen som innehåller katalogen hanteras av en **domänkontrollant (domain controller, DC)**

Domänkontrollanten (domain controller, DC)

- **Domänkontrollanten** är servern som hanterar domänen och dess objekt (användare, grupper, datorer, etc.)
- Även i en liten miljö bör man minst ha två stycken DC, och som minst en per site/kontor, beroende på storlek kan även fler vara nödvändigt
- **Read-only domain controller (RODC)** är en variant på en domänkontrollant som endast har en kopia på domänens databas som är read-only. Kan användas i (åtminstone) två fall:
  - I miljöer med lägre säkerhet
  - I miljöer med dålig eller intermittent internetanslutning

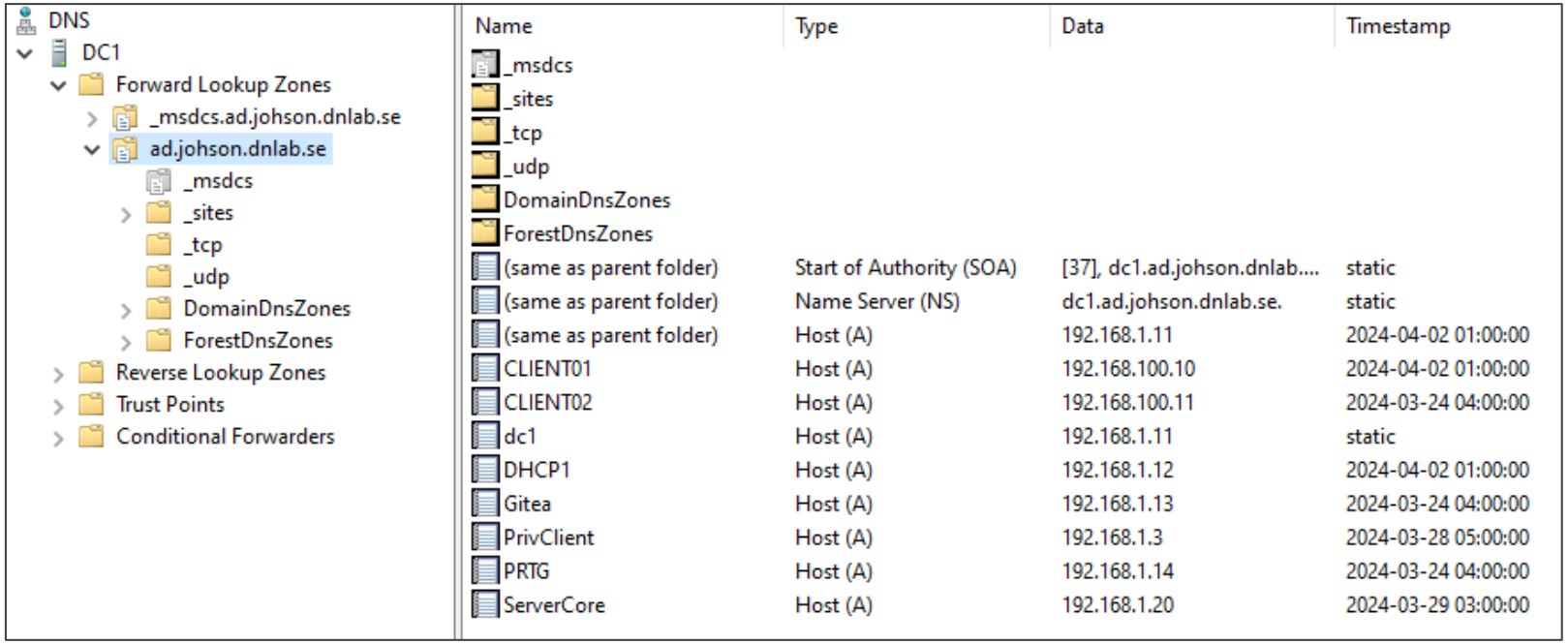
AD DS domain

- En domän (**domain**) är en logisk behållare (**container**) för att hantera användare, datorer, grupper och andra objekt
- Databasen i AD DS lagrar alla dessa objekt och varje domänkontrollant har en kopia av databasen
- Vi kommer gå in mer på olika roller som en domänkontrollant kan anta



AD <3 DNS

- AD DS bygger på DNS för att klienter och domänkontrollanter ska hitta varandra i domänen
- När AD DS installeras kommer en DNS också att följa med om man inte aktivt väljer bort det
- AD DS kommer skapa såkallade *AD Integrated DNS zones*



AD-objekt

Tre viktiga objekt

- Användare (**user objects**)
- Grupper (**group objects**)
- Datorer (**computer objects**)

- Ett sätt att hantera och gruppera ovanstående objekt är med **OUs (organizational units)**

Användare (user objects)

- En användare består av användarnamn, lösenord och gruppmedlemskap, utöver detta också en myriad av olika inställningar och regler
- Användare kan hanteras i flera olika vyer, t.ex.:
  - Active Directory Administrative Center
  - Active Directory Users and Computers
  - Windows Admin Center
  - Windows PowerShell
  - dsadd (ett CLI för AD)
- Användare placeras som standard i en inbyggd **container** som kallas “Users”, härifrån bör objektet flyttas till en **OU**

Datorer (computer objects)

- Är likt användare en såkallad **security principal** genom att de:
  - Har ett konto med ett inloggningsnamn
  - De autentiserar sig mot domänen
  - Är medlemmar av grupper och har tillgång till resurser
- När en dator är med i ett AD (AD-joinad) går det bland annat:
  - Konfigurera datoregenskaper via domänkontrollanten
  - Flytta datorn mellan OU
- Ligger som standard i en inbyggd **container** som kallas “Computers”, härifrån bör objektet flyttas till en **OU**

Grupper (group object)

- Rättigheter kan tilldelas direkt till användare, men det är ofta ohållbart i en större miljö
- Rättigheter brukar istället tilldelas grupper som delas in i två typer:
- **Security groups** hanterar regler och rättigheter och används för att tilldela resurser till vissa användare
- **Distribution groups** kan inte tilldelas regler och rättigheter utan används huvudsakligen som sändlistor (t.ex. Dist-JTH-TGNV2 som samlar alla studenter som går på NICS)

Fyra olika group scopes

- Lokala grupper (**Local groups**)
  - Används för att tilldela förmågor och rättigheter på lokala resurser i en maskin
- Domänlokala grupper (**Domain-local group**)
  - Hanterar tillgång till resurser och rättigheter inom en domän
- Globala grupper (**Global groups**)
  - Används för att samla ihop användare som har samma egenskaper, t.ex. att de arbetar på samma avdelning. Gruppen kan tilldelas rättigheter var som helst i en *forest*, men användare kan endast vara från den lokala domänen
- Universella grupper (**Universal groups**)
  - Används i miljöer med flera domäner och kombinerar funktioner för både domain-local samt global groups. Kan tilldelas resurser i en hel *forest*, användare kan också vara från var som helst i en *forest*

Vem/vad kan vara med i vilken grupp?

- **Användare** kan vara medlem i alla grupper (även om det kan vara olämpligt)
- **Lokala grupper** och **domänlokala** kan inte vara medlemmar i några grupper
- **Globala grupper** kan vara medlemmar i lokala, domänlokala, universella och andra globala grupper (inom samma domän)
- **Universella grupper** kan vara medlemmar i lokala, domänlokala, globala och andra universella grupper

AGDLP

- **A**ccount, **G**lobal, **D**omain **L**ocal, **P**ermission (**AGDLP**) är Microsofts rekommendation för implementation av **Role-Based Access Control (RBAC)**
- Exempel:
  - Lägg till användare (**Accounts**) i globala grupper (**Global Groups**)
  - Ge en lokal/domänlokal grupp (**Domain Local Groups**) tillgång (**Permission**) till en resurs, t.ex. en skrivare eller en share
  - Lägg till den globala gruppen med användare som medlem i den lokala/domänlokala gruppen ovan

Standargrupper

- Det finns ett antal lokala och globala standardgrupper
- En lokal grupp (**local group**) som finns på alla maskiner som standard är *Local Admins* som definierar vem som har administratörsrättigheter på den lokala maskinen
- När en dator joinas i en domän läggs den globala gruppen (global group) *Domain Admins* till i *Local Admins*
- Detta gör att användarna som är med i *Domain Admins* också är *Local Admins* på domänjoinade datorer

Organizational Unit (OU)

Organisationsenheter (Organizational Units, OU)

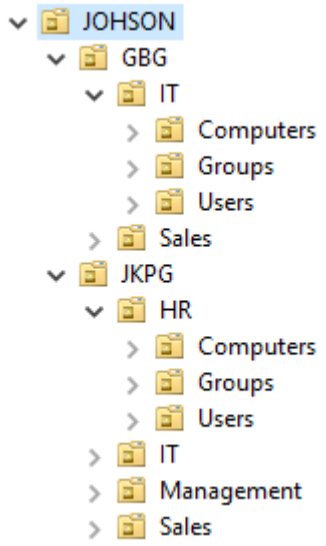
- En **OU (organizational unit)** är en behållare för objekt (användare, datorer, grupper) i en domän som kan användas för att gruppera objekt
- Används för flera saker, men huvudsakligen för att kunna applicera olika regler och rättigheter
- Förutom OU finns det också ett antal generiska containers (t.ex. *Users* där användare hamnar automatiskt), notera att det ej går applicera GPO på dessa
- För att kunna administreras på ett effektivt sätt är det viktigt att ha en bra OU-struktur

OU-struktur

- Det finns flera sätt att tänka kring designen kring OU-struktur i stort baseras det på följande:
  - Typ av organisation, ett företag har andra krav än en skola
  - Hur regler ska appliceras på användare och datorer
  - Storlek på organisationen
- Bör byggas för att förenkla användning av GPO samt att förenkla administration
- Baseras ofta på tre faktorer:
  - **Geografi**, t.ex. JKPG, STHLM, GBG
  - **Avdelningar**, t.ex. HR, IT, Sales
  - **Typ av objekt**, t.ex. användare, datorer och grupper (även servrar och skrivare brukar inkluderas med egna OU)

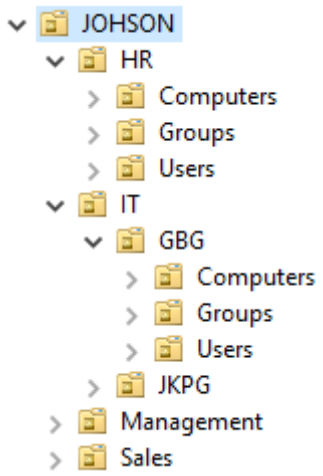
OU-struktur: Variant 1 (Geografi)

- Skapa en grund-OU med samma namn som domänen, t.ex. JOHSON om domänen är AD.JOHSON.SE
- Lägg till en OU per geografisk plats, t.ex. *JKPG, GBG*
- Lägg till en OU per avdelning, t.ex. *HR, IT*
- Lägg till en OU per typ av objekt, t.ex. *Users, Computers, Groups*



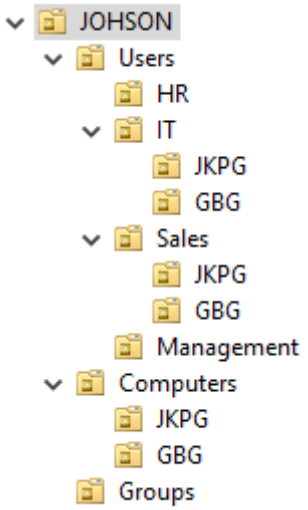
OU-struktur: Variant 2 (Organisation)

- Skapa en grund-OU med samma namn som domänen, t.ex. JOHSON
- Lägg till en OU per avdelning, t.ex. *HR, IT*
- Lägg till en OU per geografisk plats, t.ex. *JKPG, GBG* där det är nödvändigt
- Lägg till en OU per typ av objekt, t.ex. *Users, Computers, Groups*



OU-struktur: Variant 3 (Objekt)

- Skapa en grund-OU med samma namn som domänen, t.ex. JOHSON
- Lägg till en OU per typ av objekt, t.ex. *Users, Computers, Groups*
- Lägg till en OU per avdelning, t.ex. *HR, IT* där det passar (t.ex. under *Users*)
- Lägg till en OU per geografisk plats, t.ex. *JKPG, GBG* där det passar (t.ex de avdelningar som har denna indelning)



OU-struktur: Jämförelse

Geografi

- JOHSON
  - GBG
    - IT
      - Computers
      - Groups
      - Users
    - Sales
  - JKPG
    - HR
      - Computers
      - Groups
      - Users
    - IT
    - Management
    - Sales

Organisation

- JOHSON
  - HR
    - Computers
    - Groups
    - Users
  - IT
    - GBG
      - Computers
      - Groups
      - Users
    - JKPG
  - Management
  - Sales

Objekt

- JOHSON
  - Users
    - HR
    - IT
      - JKPG
      - GBG
    - Sales
      - JKPG
      - GBG
    - Management
  - Computers
    - JKPG
    - GBG
  - Groups

OU-struktur: Variant 4 (best-practice)

- **Best-practice:** Anpassa så som verksamheten ser ut och vad som gör det lätt att administrera och applicera regler och policies, alla organisationer är unika (kanske är en kombination av flera varianter rätt val)
- Här hittar ni bra tips från någon med erfarenhet: https://activedirectorypro.com/active-directory-management-tips/

Distinguished name

- Varje objekt i en domän har ett **distinguished name (DN)** som består av tre komponenter:
  - **commonName (CN)**
  - **organizationalUnitName (OU)**
  - **domainComponent (DC)**
- Exempel 1 på DN (allt är i OU):

CN=Sonny Johansson,OU=Users,OU=JKPG,OU=IT,OU=JOHSON,DC=ad,DC=johson,DC=dnlab,DC=se

- Exempel 2 på DN (användare i container):

CN=Test,CN=Users,DC=ad,DC=johson,DC=dnlab,DC=se

Livelabb: Användare och grupper

- Skapa upp en OU-struktur
- Skapa ett antal användare
- Skapa grupper för varje avdelning där användarna ingår

- Notera att ni i Hyper-V kan behöva stänga av Enhanced Session om ni loggar in med användare som har för låg behörighet i domänen. Detta beror på att Hyper-V Enhanced Session bygger på RDP och inte har rätt behörighet att logga in.

JÖNKÖPING UNIVERSITY

Group Policy Object (GPO)

GPO (Group Policy Objects)

- **GPO (Group Policy Objects)** ger administratören möjlighet att centralt styra regler och inställningar för användare och datorer i en domän
- Dessa policies kan appliceras till en enskild dator/användare eller till hela domänen, som regel appliceras de dock via en OU
- GPO används till:
  - Öka säkerheten genom att begränsa vissa handlingar
  - Bestämma inställningar som användare själv inte ska få definiera
  - Standardisera skrivbordmiljöer så att alla datorer har samma inställningar
  - Distribuera applikationer
  - Dela ut resurser

Vad kan hanteras med GPO?

- Allt som finns i registret gällande datorn och användaren, alltså:
  - **Computer Configuration** (HKEY_LOCAL_MACHINE)
  - **User Configuration** (HKEY_CURRENT_USER)
- Inställningar
- Utskickning av mjukvara/applikationer
- Mappning av nätverkskataloger, gemensamma eller hemkataloger

Applicera GPO

- Görs i **Group Policy Management Editor**
- För att hantera från en priviligierad klient måste *RSAT: Group Policy Management Tools* installeras
- Trots namnet ”Group” så appliceras GPOer till användare eller datorer som har grupperats i en OU och huvudsakligen inte till en viss grupp
  - Går dock att filtrera på grupp med *security filtering*
- GPO kan också appliceras till en hel site eller en domän

GPO-ordning (processing order)

- GPO:er läses in i följande ordning:
  1. **Local GPOs**: Lokala GPO som finns lokalt på datorn
  2. **Site-linked GPOs:** GPO som är appliceras på en hel site
  3. **Domain-linked GPOs**: GPO som är applicerade på hela domänen
  4. **OU-linked GPOs:** GPO som är applicerade på OU
  5. **Child OU-linked GPOs:** GPO som är applicerade på en child OU
- Senaste och mest specifika policyn är den som gäller

Grupper vs. OU

- En användare är som regel med i både i OU och ett antal grupper, vad är skillnaden på dessa?

- **OU** används som regel för att applicera regler och inställningar, t.ex. att begränsa tillgång till en viss applikation. Att man bara är med i ett OU möjliggör detta genom att flera regler inte kan gälla samtidigt
- **Grupper** används som regel för att ge tillgång till olika resurser t.ex. skrivare, shares, maskiner, etc. där flera grupper inte konkurrerar med varandra

Livelabb: GPO (inställningar)

- Sätt en GPO som hindrar användarna på HR-avdelningen att använda regedit
  - User Configuration/Policies/Administrative Templates/System/Prevent access to registry editing tools

- Sätt en GPO som tvingar en bakgrundsbild för användarna på IT-avdelningen
  - User Configuration/Policies/Administrative Templates/Desktop/Desktop/Desktop Wallpaper

Livelabb: GPO (shares)

- Tilldela en gemensam katalog för en avdelning
  - User Configuration/Preferences/Windows Settings/Drive Maps/New Drive

- <u>Först lite repetition om shares:</u>
- Görs i Windows via **SMB (Server Message Block)**
- Använder sig av **UNC (Universal Naming Convention)**, t.ex. *\\address\share*
- Glöm inte att en share måste matcha både NTFS- och SMB-rättigheter
  - Ett sätt är att ge ”Authenticated Users” full tillgång via SMB och reglera med NTFS

JÖNKÖPING UNIVERSITY

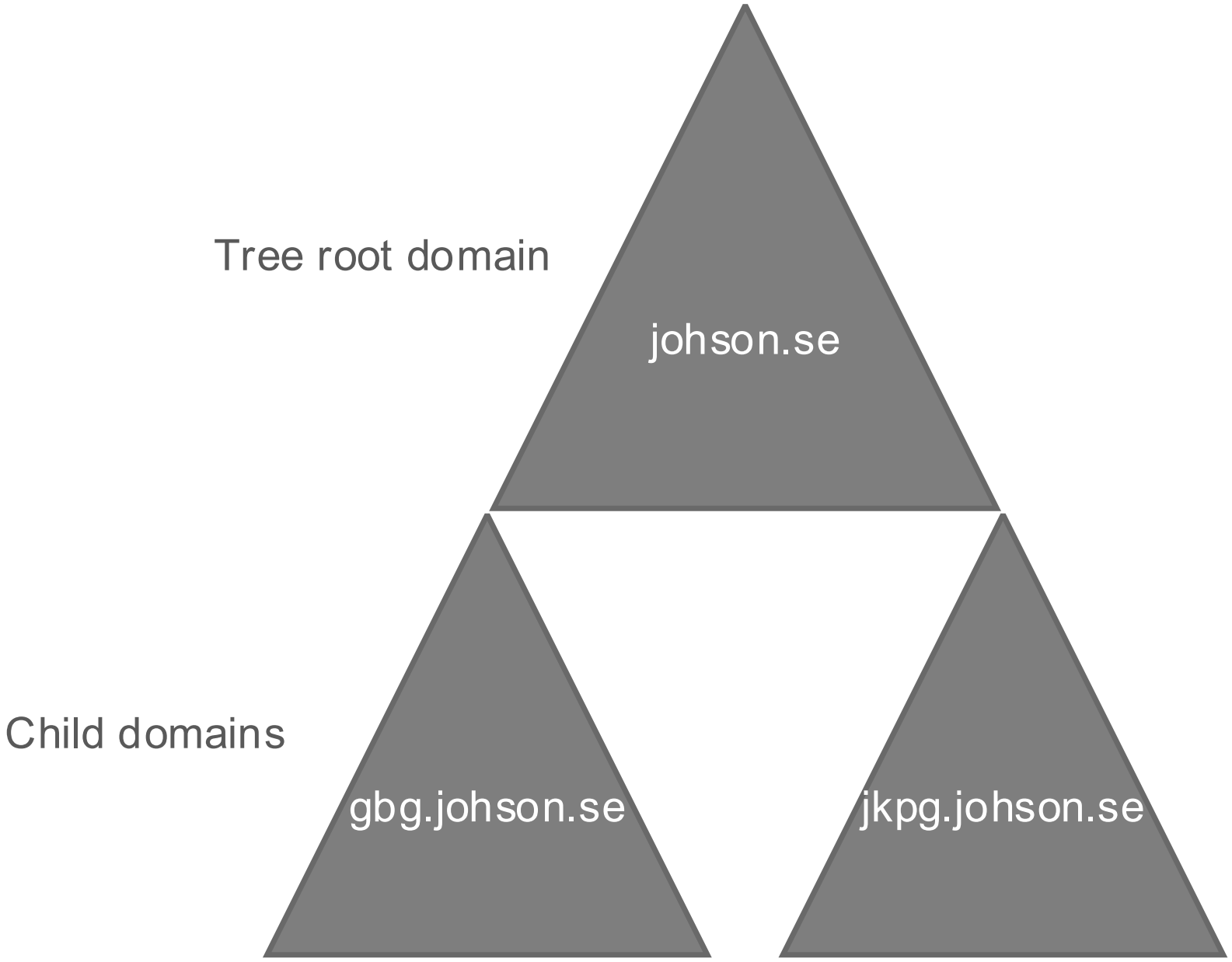
Avancerade AD-koncept

Domain, tree, forest, FSMO-roller och AD-säkerhet

Domains & trees

- En **domain** är logisk grupp av objekt (användare, grupper, datorer) som delar samma AD-databas, t.ex. **johson.se**
- En **child domain** är en domain som är en del av (delar samma avslutande namespace) en annan domain, t.ex. **gbg.johson.se**
- En domain tillsammans med en eller flera child domains skapar ett **tree**
- Domänen johson.se är i toppen av strukturen och är då en **tree root domain**
- Varje domain i trädet har sina egna användare, grupper och datorer och därmed sin egna AD-databas

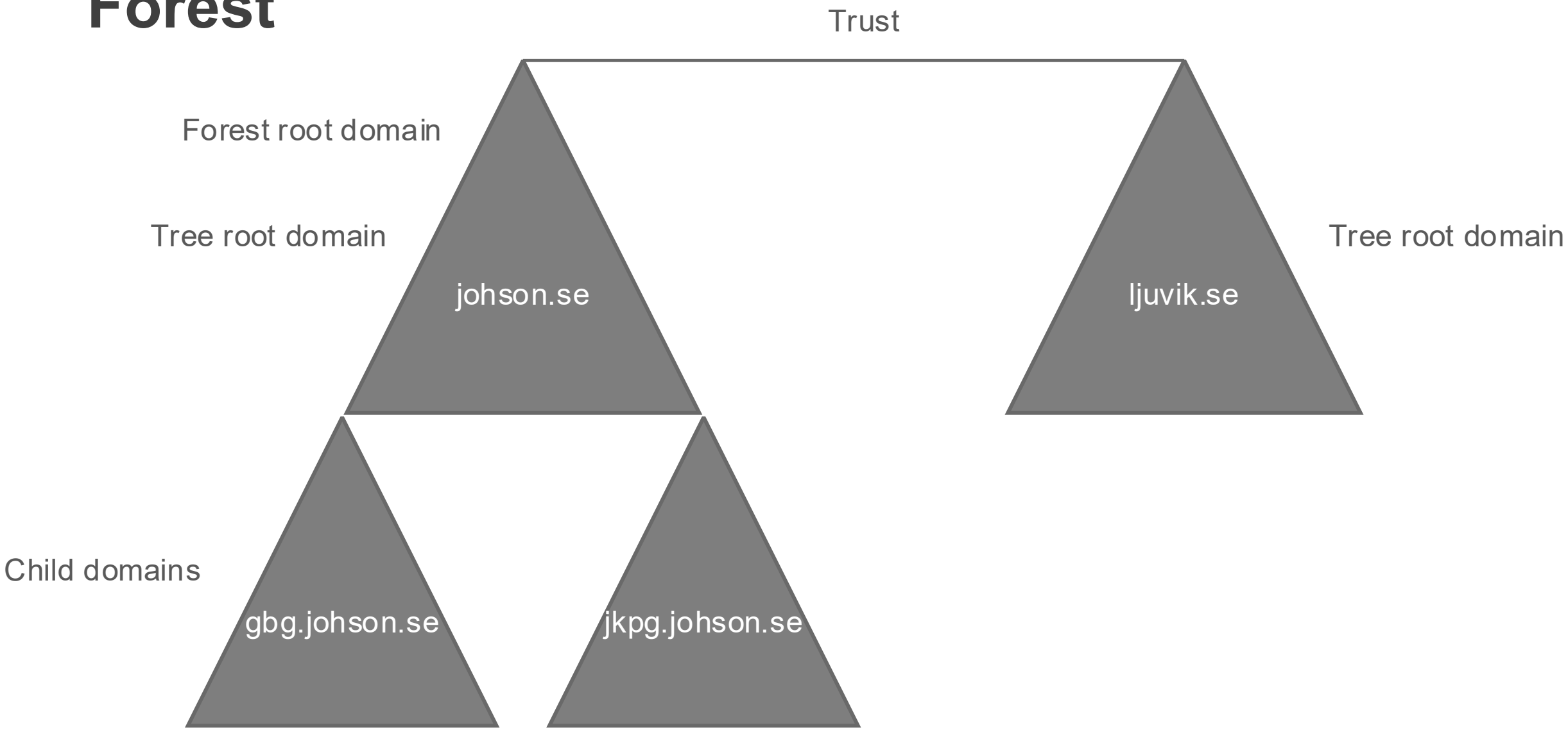
Tree


Tree root domain
johson.se
Child domains
gbg.johson.se
jkpg.johson.se

Forest

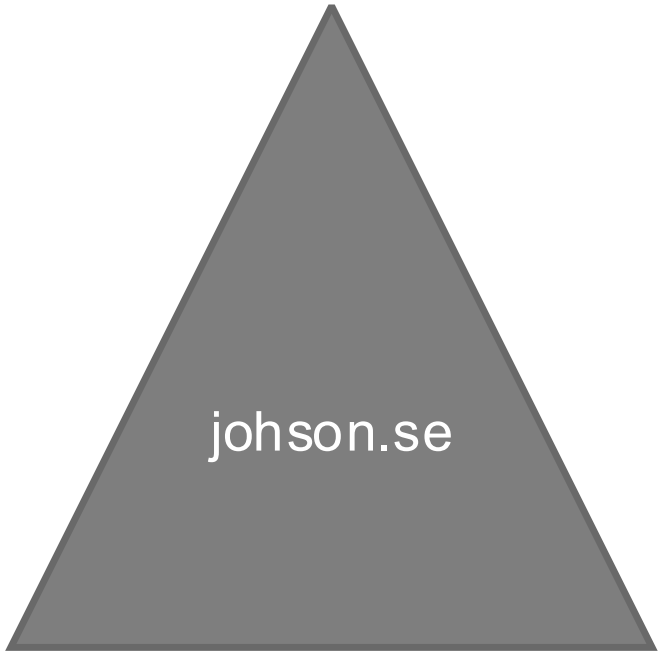
- En **forest** är en samling av ett eller flera **domain trees**
- En **forest root domain** är den första domänen som skapas i en **forest**
- Domains i en och samma forest delar:
  - En gemensam **root domain**
  - En **global catalog** som innehåller ett index över alla objekt i en forest

Forest


Trust
Forest root domain
Tree root domain
johson.se
ljuvik.se
Tree root domain
Child domains
gbg.johson.se
jkpg.johson.se

Notera!

- Tekniskt sett är en ensam domän utan *child domains* eller *trusts* alla roller:
  - En **domain**
  - Ett **tree**
  - En **forest**
- Begreppet används alltså även i mindre AD-miljöer



Trusts

- En **trust** är en relation mellan olika domains, de vanligaste är:
- **Parent-child trusts** som är mellan domains inom samma tree
- **Tree-root trust** som är mellan trees (och skapar en forest)
- Ovanstående trusts är **transitive trusts** vilket innebär att de även litar på övriga domains som ingår
- Ovanstående är även **two-way trusts** vilket innebär att de delar informationen åt båda håll
- Det finns även trusts som är **nontransitive** och **one-way**

FSMO-roller

- Förändringar i en domän kan skrivas till vilken DC som helst i domänen (detta kallas **Multi-Master**), vissa roller är dock skyddade och kan endast hanteras på ansvarig DC
- **Flexible Single Master Operation (FSMO)** är ett sätt att hantera dessa fem roller som kan spridas ut på flera domänkontrollanter eller antas av en enskild domänkontrollant
  - **Schema master**, hanterar attribut och objekt som krävs ex. för användare
  - **Domain naming master**, hanterar namespace och nya domäner i en forest
  - **RID master**, hanterar unika objekt-ID för nya objekt
  - **PDC emulator**, synkroniserar tiden
  - **Infrastructure master**, hanterar referenser till objekt mellan olika domäner

https://blog.netwrix.com/2021/11/30/what-are-fsmo-roles-active-directory/

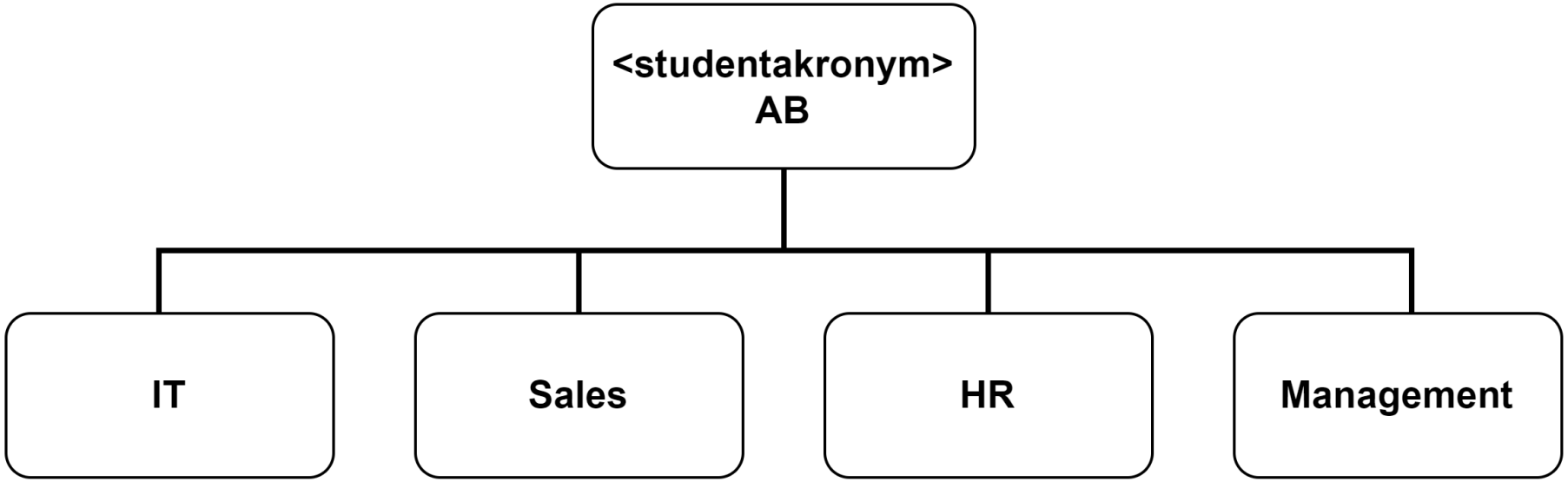
Autentisering via AD

- Autentisering via AD går via ett av två protokoll:
- **Kerberos** körs av alla aktuella versioner av Windows
  - Baseras på **tickets**, d.v.s. att användare autentiserar sig mot AD och får en biljett, denna kan sedan användas för att autentisera sig mot flera tjänster
  - Tickets levereras av tjänsten **KDC (Key Distribution Center)** som är lokaliserad på en domänkontrollant
- **NetNTLM** finns kvar av legacy-skäl
  - Autentisering mot domänkontrollanten sker varje gång användaren vill autentisera sig mot en tjänst

AD-säkerhet

- Går att prata en hel föreläsning (eller kurs) om
- Microsoft nämner ett par best-practice för **AD-säkerhet**:
  - **Tilldela inte för mycket rättigheter**, applicera **least privilege administration**, använd t.ex. inte användare i gruppen *Domain Admins* till allt (som vi har gjort hittills)
  - Använd **säkra enheter och konton** för krävande administration
  - **Håll domänkontrollanter extra säkra** både fysiskt och logiskt, säkra upp med GPOer, en DC ska inte kunna nå eller vara nåbar från Internet
  - **Övervaka AD** för attacker och intrång
  - **Planera för incidenter**, ha **backuper** och **återställningsplaner**

Laboration 2



kahoot.it

JÖNKÖPING UNIVERSITY